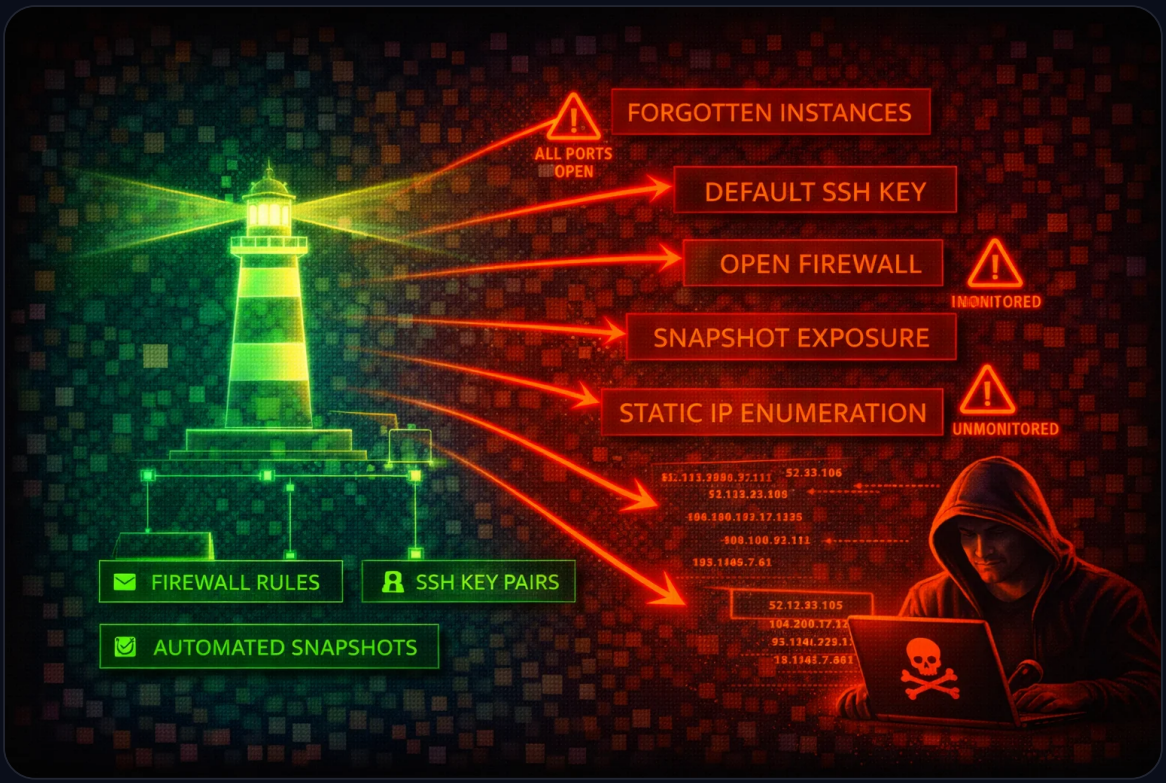

Amazon Lightsail Security

COMPUTE

Amazon Lightsail provides simplified virtual private servers, managed databases, object storage, and container services. Its simplified interface masks real security risks: default SSH keys shared across all instances in a region, firewall rules open to 0.0.0.0/0 by default, and forgotten instances running unpatched software.

HIGH	Regional	Instance-level	Default + Custom
Risk Level	Scope	Firewall	Key Mgmt

📋 Service Overview

Instance Firewall

Each instance has IPv4 and IPv6 firewalls controlling inbound traffic only (allow, no deny). Default blueprints ship with SSH (22) and HTTP (80) open to all IPs. All outbound traffic allowed.

Attack note: Default firewall rules expose SSH to 0.0.0.0/0 on every Linux instance at creation. When multiple rules exist for the same port, the most permissive rule wins.

Default SSH Keys and Access

Lightsail creates one default SSH key pair per AWS Region. The private key is downloadable via console or CLI. Every instance in the region uses this same default key unless overridden.

Attack note: Anyone with Lightsail API access can download the regional default private key or request temporary SSH credentials, gaining shell access to every instance using that key.

Security Risk Assessment

8.0

Risk Score

Lightsail instances are frequently deployed by non-security-focused teams, left unmonitored, and forgotten. Default SSH keys shared per region, permissive default firewall rules, IMDSv1 enabled by default on most blueprints, and limited CloudTrail visibility make Lightsail a high-value target.

⚔️ Attack Vectors

Credential & Key Theft

- Download regional default SSH key via API
- Retrieve temporary SSH keys via get-instance-access-details
- Retrieve RDP admin password for Windows instances
- Retrieve database master password via API
- SSRF to IMDS (IMDSv1 enabled by default on most blueprints)

Instance & Network Exploitation

- Brute-force SSH on default open port 22
- Exploit unpatched blueprint apps (WordPress, LAMP)
- Abuse exported snapshots with residual SSH keys
- Pivot from peered VPC (firewall bypassed on private IP)
- Access forgotten/abandoned instances

⚠️ Misconfigurations

Firewall & Network

- SSH (22) or RDP (3389) open to 0.0.0.0/0 (default)
- No source IP restriction on admin ports
- All outbound traffic allowed (no egress filtering)
- IPv6 firewall rules not configured separately
- No VPC flow logs (managed VPC)

Instance & Data

- IMDSv1 enabled on most blueprints (default)
- Using shared default key instead of per-instance custom keys
- Automatic snapshots not enabled
- Database publicly accessible with default credentials
- Exported snapshots retain residual Lightsail SSH keys

🔍 Enumeration

List All Instances

```
aws lightsail get-instances
```

Get Instance Firewall Port States

```
aws lightsail get-instance-port-states \
  --instance-name my-instance
```

Download Regional Default SSH Key

```
aws lightsail download-default-key-pair
```

Get Temporary SSH Access Credentials

```
aws lightsail get-instance-access-details \
  --instance-name my-instance --protocol ssh
```

List All Databases

```
aws lightsail get-relational-databases
```

📈 Privilege Escalation

From API Access to Instance Shell

- download-default-key-pair to get regional private key
- get-instance-access-details for temporary SSH credentials
- get-relational-database-master-user-password for DB access
- open-instance-public-ports to expose services
- export-snapshot to EC2 for data extraction

From Instance Shell to AWS Account

- Query IMDS for IAM role credentials
- Read application config files with AWS access keys
- Pivot to peered VPC resources via private IP
- Create instance snapshots for exfiltration
- Access other instances via shared default key

Key insight: download-default-key-pair and get-instance-access-details are uniquely dangerous -- they directly return SSH private keys and passwords, unlike EC2.

🔗 Persistence

Instance-Level

- Maintain SSH access via default or custom key
- Plant backdoors on instance filesystems
- Install cron jobs for persistent access
- Create snapshots for future restoration
- Modify firewall rules for continued network access

Account-Level

- Exfiltrate credentials for out-of-band access
- Export snapshots to EC2 for offline analysis
- Create additional instances as backup access
- Maintain database credentials for data access
- Peer VPC for persistent network path

🛡️ Detection

CloudTrail Events

- DownloadDefaultKeyPair - SSH key downloaded
- GetInstanceAccessDetails - temporary creds requested
- OpenInstancePublicPorts - firewall opened
- PutInstancePublicPorts - firewall rules replaced
- ExportSnapshot - snapshot exported to EC2

Indicators of Compromise

- Key downloads from unusual principals
- Firewall modifications adding broad access
- Database password retrieval from unexpected sources
- Instance access details requested frequently
- Snapshot exports to unknown regions

💻 Exploitation Commands

Download Default Key and SSH In

```
aws lightsail download-default-key-pair \
  --query 'privateKeyBase64' --output text > lightsail-key.pem
chmod 600 lightsail-key.pem
ssh -i lightsail-key.pem ubuntu@<instance-ip>
```

Open All Ports on an Instance

```
aws lightsail open-instance-public-ports \
  --instance-name my-instance \
  --port-info fromPort=0,toPort=65535,protocol=all
```

Retrieve Database Master Password

```
aws lightsail get-relational-database-master-user-password \
  --relational-database-name my-db \
  --password-version CURRENT
```

Export Snapshot to EC2

```
aws lightsail export-snapshot \
  --source-snapshot-name my-instance-snapshot
```

📜 Policy Examples

✗ Dangerous - Full Lightsail Access

```
{
  "Effect": "Allow",
  "Action": "lightsail:*",
  "Resource": "*"
}
```

Grants access to download SSH keys, retrieve database passwords, modify firewalls, and delete all resources

✓ Secure - Read-Only Monitoring

```
{
  "Effect": "Allow",
  "Action": [
    "lightsail:GetInstances",
    "lightsail:GetInstanceState",
    "lightsail:GetInstancePortStates"
  ],
  "Resource": "*"
}
```

Read-only monitoring -- cannot download keys, open ports, or modify resources

✓ Secure - Deny Credential Retrieval

```
{
  "Effect": "Deny",
  "Action": [
    "lightsail:DownloadDefaultKeyPair",
    "lightsail:GetInstanceAccessDetails",
    "lightsail:GetRelationalDatabaseMasterUserPassword"
  ],
  "Resource": "*"
}
```

Prevents credential theft and firewall modification -- the most dangerous Lightsail actions

Defense Recommendations

Enforce IMDSv2

Require session tokens for IMDS access on all Lightsail instances.

```
aws lightsail update-instance-metadata-options \
  --instance-name my-instance \
  --http-tokens required --http-endpoint enabled
```

Restrict SSH to Known IPs

Replace default all-IPs SSH rule with source IP restrictions.

```
aws lightsail put-instance-public-ports --instance-name
my-instance \
  --port-infos
'[{"fromPort":22,"toPort":22,"protocol":"tcp","cidrs":
["203.0.113.0/24"]}]'
```

Use Custom Key Pairs

Create per-instance or per-team custom key pairs. Stop using the shared regional default key.

```
aws lightsail create-key-pair --key-pair-name prod-web-
key
```

Enable Automatic Snapshots

Protect against ransomware and accidental deletion with daily automatic snapshots.

```
aws lightsail enable-add-on --resource-name my-instance
\
  --add-on-request
addOnType=AutoSnapshot,autoSnapshotAddOnRequest={snapsh
otTimeOfDay=06:00}
```

🚫 **Deny Dangerous API Actions via IAM**

Explicitly deny DownloadDefaultKeyPair, GetInstanceAccessDetails, and GetRelationalDatabaseMasterUserPassword.

🔍 **Audit and Decommission Forgotten Instances**

Regularly enumerate all Lightsail instances across all regions. They do not appear in EC2 console.

Always obtain proper authorization before testing